Voult — Password Manager: Requirements & Implementation Plan

Oct 30, 2026 · @Francisco Oliveira

1. Scope

A self-hosted, zero-knowledge password manager at Proton Pass parity, plus a built-in 2FA client and passkeys, shipped as a Chrome/Firefox extension and an Android app, all TypeScript, with nightly encrypted backups to Google Drive. Name: **Voult**.

Goals

- One encrypted vault, synced across extension and Android in seconds.
- Autofill everywhere: web forms (extension) and any Android app/browser (Autofill Service).
- TOTP codes always at hand, added by camera QR (mobile) or secret key (both).
- Server and Google never see plaintext. Losing the server never loses data (Drive backup restores standalone).

Non-goals (v1): multiple users (schema stays ready for it), sharing between users, email aliases, public store listings, iOS, desktop app, web vault.

2. Feature set

P0 = v1 must-have, P1 = v1 if time allows, P2 = later. Ext = extension, And = Android.

ID	Feature	Ext	And	Priority
Vault & items				
F1	Login item: title, username, email, password, multiple URLs, notes, custom fields (text/hidden/TOTP)	✓	✓	P0
F2	Secure note item (markdown-lite)	✓	✓	P0
F3	Credit card and identity items	✓	✓	P1

ID	Feature	Ext	And	Priority
F4	Multiple vaults (name, colour, icon); move items between vaults	✓	✓	P1
F5	Search (title, username, URL, note), filters by type/vault, sort, favourites/pin	✓	✓	P0
F6	Trash with restore and auto-purge after 30 days	✓	✓	P0
F7	Item history: last 10 password versions	✓	✓	P1
F8	Copy username/password/code with clipboard auto-clear (30 s, configurable)	✓	✓	P0
F9	Website icons via privacy-safe favicon proxy (server-side, cached)	✓	✓	P1
Password generator				
G1	Random: length 4–64, upper/lower/digits/symbols toggles, exclude ambiguous (Il1O0)	✓	✓	P0
G2	Memorable passphrase: EFF wordlist, 3–10 words, separator, capitalise, append digit	✓	✓	P0
G3	Strength meter (zxcvbn-ts) and generator history (last 20, encrypted)	✓	✓	P1
G4	Generate inline from a password field (icon/context menu)	✓	✓	P0
2FA / TOTP client				
T1	TOTP (RFC 6238) and HOTP (RFC 4226); SHA1/256/512, 6–8 digits, 15/30/60 s periods	✓	✓	P0

ID	Feature	Ext	And	Priority
T2	Add by secret key ("passphrase") with manual issuer/account/algorithm	✓	✓	P0
T3	Add by camera QR scan (`otpauth://` URI)	—	✓	P0
T4	Add by scanning a QR visible on the current tab (capture tab + decode)	✓	—	P1
T5	Standalone 2FA entries and TOTP attached to a login item	✓	✓	P0
T6	Authenticator screen: all codes, countdown ring, search, tap to copy, next-code preview	✓	✓	P0
T7	Autofill TOTP into OTP fields after login autofill	✓	✓	P0
T8	Import Google Authenticator export QR (`otpauth-migration://`), Aegis, 2FAS	✓	✓	P1
Browser extension (Chrome + Firefox, MV3)				
E1	Popup: unlock, item list scoped to current site, full vault, detail/edit, generator, authenticator	✓		P0
E2	Login form detection, inline field icon, dropdown of matching items, one-click fill	✓		P0
E3	Save/update prompt after form submit (new login or changed password)	✓		P0
E4	Keyboard shortcut autofill (Ctrl/Cmd+Shift+L), context menu entries	✓		P1

ID	Feature	Ext	And	Priority
E5	URL matching rules: base domain (PSL), exact host, regex; never-fill list	✓		P0
E6	Iframe and shadow-DOM forms; multi-step logins (username then password page)	✓		P1
Android app (Expo)				
A1	Vault UI parity with the extension (list, detail, edit, generator, authenticator)		✓	P0
A2	Android Autofill Service: fill credentials in any app and browser, app↔domain matching (Digital Asset Links)		✓	P0
A3	Inline autofill suggestions in the keyboard (Android 11+)		✓	P1
A4	Save prompt from Autofill Service (SaveRequest)		✓	P0
A5	Biometric unlock (fingerprint/face) and PIN unlock		✓	P0
A6	Home-screen widget / quick-settings tile for 2FA codes		✓	P2
A7	Screenshot blocking (FLAG_SECURE) on vault screens		✓	P0
Security & account				
S1	Master password + recovery kit (printable secret key)	✓	✓	P0
S2	Auto-lock: on idle (1/5/15/60 min), on browser close, on screen off	✓	✓	P0
S3	Password health: weak, reused, old, breached (HIBP k-anonymity), missing 2FA	✓	✓	P1

ID	Feature	Ext	And	Priority
S4	Device list with revoke; session per device	✓	✓	P1
S5	Change master password (re-wrap keys, no item re-encryption)	✓	✓	P0
Sync, backup, import/export				
B1	Real-time sync of encrypted items via self-hosted server; offline-first with conflict handling	✓	✓	P0
B2	Periodic encrypted backup to Google Drive (daily default, keep last 30), "Backup now" button	✓	✓	P0
B3	Restore from Drive backup or local file into a fresh install, server not required	✓	✓	P0
B4	Import: Proton Pass, Bitwarden, 1Password, Chrome/Firefox CSV	✓	✓	P0
B5	Export: encrypted `.vault` file and plaintext CSV/JSON (with warning)	✓	✓	P0
UX				
U1	Modern UI: light/dark/system theme, shared design tokens, motion, empty states	✓	✓	P0
U2	i18n (EN, PT)	✓	✓	P1
U3	Passkeys: create, store, sync and sign in with WebAuthn passkeys; extension handles navigator.credentials on any site, Android acts as a Credential Manager provider (Android 14+)	✓	✓	P0

3. Security & non-functional requirements

All encryption happens on the client; the server and Google Drive store only ciphertext and KDF parameters.

Key hierarchy

1. **Master key** = Argon2id(master password, salt; m = 64 MiB, t = 3, p = 1). Never stored, never sent.
2. **Auth key** = HKDF(master key, "auth"). Sent at login; server stores Argon2id(auth key) only.
3. **Key-encryption key (KEK)** = HKDF(master key, "enc"). Wraps the account key.
4. **Account key**: random 256-bit, stored server-side wrapped by KEK (and by the recovery secret key).
5. **Vault keys**: random per vault, wrapped by the account key.
6. **Item keys**: random per item, wrapped by the vault key; item JSON encrypted with its item key.

Cipher: XChaCha20-Poly1305 (24-byte random nonce), item ID + version as AAD. Libraries: `@noble/ciphers`, `@noble/hashes`, Argon2 via `hash-wasm` (extension) and a native Argon2 module (Android, for speed). Changing the master password re-wraps only the account key.

Local unlock

- Extension: decrypted account key held in `chrome.storage.session` (memory only, cleared on browser close; Firefox 115+). Optional PIN = Argon2id(PIN) wrapping a session key, 5 attempts then full lock.
- Android: account key wrapped by an Android Keystore key requiring biometric auth (`setUserAuthenticationRequired`), so a stolen phone without biometrics yields nothing.

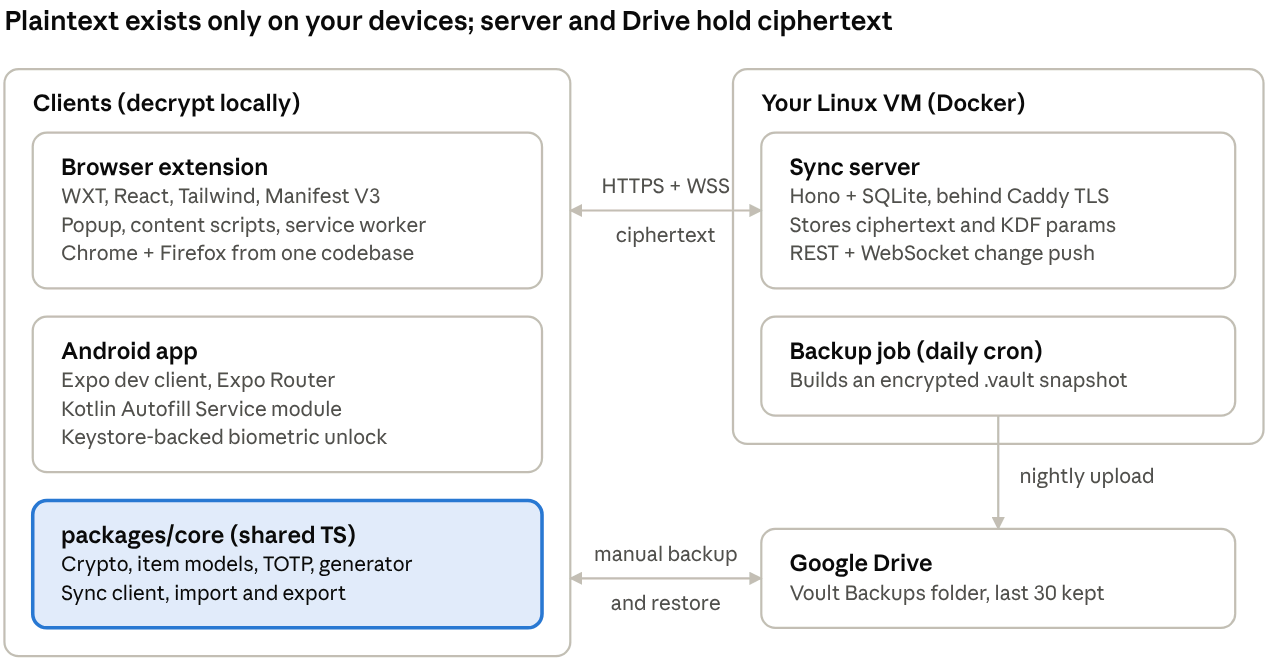
Requirements

- NFR1 Unlock < 1 s on a mid-range phone; popup open < 300 ms; autofill dropdown < 150 ms.
- NFR2 Offline-first: all features work without network; sync on reconnect.
- NFR3 No plaintext in logs, crash reports, clipboard history (Android: `EXTRA_IS_SENSITIVE`), or screenshots.

- NFR4 Content scripts never receive secrets until the user picks an item; fill happens via message to the target frame only, origin-checked.
- NFR5 Strict CSP, no remote code, no analytics. Dependencies pinned and audited in CI.
- NFR6 Core crypto and TOTP covered by RFC test vectors; ≥ 90 % coverage in `packages/core`.
- NFR7 Server: TLS only, rate-limited login (5/min/IP), short-lived JWT access + rotating refresh tokens per device.
- NFR8 Accessibility: WCAG 2.1 AA contrast, full keyboard use in the extension, TalkBack labels on Android.

4. Architecture

Two TypeScript clients share one core package; a small self-hosted sync server on your Linux VM moves ciphertext between them and pushes a daily encrypted snapshot to Google Drive.



system architecture · 2 clients, 1 shared core, self-hosted sync, Drive backup

The Drive snapshot is self-contained (KDF params + wrapped keys + items), so the master password alone restores it even if the VM is gone.

Stack

Layer	Choice
Monorepo	pnpm workspaces + Turborepo, TypeScript 5 strict, ESLint + Prettier
Extension	WXT (MV3, Chrome + Firefox builds), React 19, Tailwind v4, shadcn/ui, Zustand, Dexie (IndexedDB)
Android	Expo SDK (dev client / prebuild, not Expo Go), Expo Router, NativeWind, Reanimated, expo-sqlite, expo-camera
Native modules	Expo Modules API in Kotlin: `AutofillService`, Keystore biometric key, Argon2, FLAG_SECURE, CredentialProviderService (passkeys)
Core	`@noble/ciphers`, `@noble/hashes`, `hash-wasm`, `otpauth`, `zxcvbn-ts`, `zod`
Server	Hono on Node 22, SQLite + Drizzle, Docker Compose, Caddy (TLS) at voult.franciscoliveira.com
Backup	Google Drive API v3, `drive.file` scope, OAuth refresh token stored encrypted on the server
QR	expo-camera barcode scanner (Android), `jsQR` on a tab capture (extension)
Tests / CI	Vitest, Playwright (extension e2e), Maestro (Android e2e), GitHub Actions + EAS Build (APK/AAB)

Repo layout

```
vault/
  apps/
    extension/     WXT: popup, options, background, content scripts
    mobile/        Expo app + modules/autofill (Kotlin)
    server/        Hono API, sync, backup cron
  packages/
    core/          crypto, schemas, vault ops, totp, generator,
import/export, sync client
    ui-tokens/     colours, spacing, type scale shared by Tailwind and
NativeWind
    config/        tsconfig, eslint, vitest presets
```

Data model (server, all secrets encrypted)

Table	Columns
users	id, email, auth_hash, kdf_params, salt, wrapped_account_key, wrapped_recovery_key, rev
devices	id, user_id, name, platform, refresh_hash, last_seen
vaults	id, user_id, wrapped_vault_key, enc_meta (name, colour, icon), rev, deleted_at
items	id, vault_id, type, wrapped_item_key, ciphertext, rev, updated_at, deleted_at
backups	id, user_id, drive_file_id, size, created_at

Item plaintext is a `zod` discriminated union on `type` (`login`, `note`, `card`, `identity`, `totp`); a login embeds an optional `totp` block (secret, algorithm, digits, period, issuer).

A login can also hold `passkeys[]` (credential ID, rpId, user handle, ES256 private key, sign counter, created date), encrypted with the item like any other field, so passkeys sync and back up with everything else.

Sync protocol

- Every write bumps a per-user `rev`. Clients pull `GET /sync?since=<rev>` and push `PUT /items/:id` with `If-Match: <item rev>`.
- WebSocket sends only "rev changed"; clients then pull.
- Conflict (409): last writer wins on metadata; if passwords differ, the losing version is kept in item history so nothing is lost.

- Offline edits queue locally and replay in order on reconnect.

5. Implementation plan

Nine phases, about 22 weeks solo; the extension becomes daily-usable at week 11 (M1), Android with autofill and passkeys at week 18.5 (M2), v1.0 at week 22 (M3). Each phase ends with its acceptance check passing in CI.

1. **Foundation (1 wk)**: monorepo, TS/ESLint/Vitest presets, `ui-tokens`, GitHub Actions, Docker Compose skeleton.
   - Accept: `pnpm build` and `pnpm test` green for empty apps; extension loads in Chrome and Firefox; Expo dev client runs on device.
2. **Core library (2.5 wk)**: key hierarchy, encrypt/decrypt, item `zod` schemas, vault operations, generator (random + EFF passphrase), TOTP/HOTP, `otpauth://` and migration-QR parsing, `.voult` export format, CSV/JSON importers, software WebAuthn authenticator (ES256 via `@noble/curves`, CBOR via `cbor-x`, `none` attestation, flags + sign counter).
   - Accept: RFC 4226/6238 vectors pass; round-trip encrypt/decrypt fuzz tests; passkey registrations and assertions verify with `@simplewebauthn/server`; Argon2 params benchmarked < 1 s on target phone; ≥ 90 % coverage.
3. **Sync server (1.5 wk)**: signup/login with auth key, devices + refresh tokens, vaults/items CRUD with `rev`, `/sync`, WebSocket push, rate limiting, Caddy TLS on your VM at voult.franciscoliveira.com. Single-user: signup closes after the first account (env flag), but every table keeps user_id so multi-user can be switched on later.
   - Accept: integration tests for conflicts (409) and offline replay; server DB dump contains no plaintext (grep test).
4. **Extension MVP (3 wk)**: onboarding (create account, recovery kit PDF), unlock/PIN, auto-lock, popup with vault list, item detail/edit, search, trash, generator, authenticator tab, passkey list on items, settings, light/dark theme.
   - Accept: Playwright e2e for create → lock → unlock → edit → sync between two browser profiles.
5. **Extension autofill + passkeys (3 wk)**: form detection heuristics, inline field icon + dropdown, fill via background→frame messaging, save/update prompt, TOTP autofill, URL matching (PSL), shortcut + context menu, QR capture from tab; passkeys: page-

world script wraps `navigator.credentials.create/get`, shows the Vault passkey picker, signs in the background worker, falls back to the browser's own UI on cancel. → **M1**
   - Accept: fills and saves on a test matrix of 20 real sites (Google, GitHub, Microsoft, banks, multi-step forms, iframes); creates and signs in with passkeys on webauthn.io, GitHub and Google; no secret reaches a content script before user choice.
6. **Android app MVP (3 wk)**: Expo Router screens at parity with the popup, biometric + PIN unlock via Keystore module, camera QR for 2FA, authenticator screen, clipboard sensitivity flag, FLAG_SECURE, offline SQLite cache.
   - Accept: Maestro flows for unlock, add login, scan QR → code matches reference app, sync with extension < 3 s.
7. **Android autofill + passkey provider (4.5 wk)**: Kotlin `AutofillService` in an Expo module + config plugin; reads an encrypted autofill index (domain/package → item IDs) written by the JS side; authentication activity to unlock and decrypt only the chosen item; SaveRequest handling; inline keyboard suggestions; Digital Asset Links app↔domain mapping; `CredentialProviderService` (Android 14+) for passkey create/get and password credentials via Credential Manager. → **M2**
   - Accept: fills in Chrome, Firefox and 10 apps (banking, social, Google login); saves new credentials; works when the app process is cold; passkey register + sign-in in Chrome Android and a native app; a passkey created on Android works in the extension and vice versa.
8. **Google Drive backup & restore (1.5 wk)**: OAuth connect from settings, server daily cron to a "Vault Backups" folder with 30-snapshot retention, "Backup now" from both clients, restore wizard on a fresh install from Drive or a local file, backup status/last-success display and failure notification.
   - Accept: wipe VM and both clients, restore from Drive with master password only, item, TOTP and passkey counts and checksums match.
9. **Hardening & release (2 wk)**: password health + HIBP, imports from Proton Pass/Bitwarden/1Password (incl. passkeys where exported), i18n EN/PT, accessibility pass, dependency audit, threat-model review, distribution: signed APK on GitHub Releases with an in-app update check, unlisted Chrome Web Store item, Firefox XPI signed via AMO unlisted (self-hosted with update_url). → **M3 v1.0**
   - Accept: external review of crypto, autofill and passkey code; all P0 features in section 2 checked off.

Working method: one branch + PR per phase sub-task; `packages/core` changes require tests first; a running `CHANGELOG.md`; each phase demoed before the next starts.

6. Risks & decisions

The Android Autofill Service is the largest risk: Expo has no built-in support, so it is native Kotlin behind an Expo module and needs a dev client build.

Risk	Mitigation
Autofill Service complexity (Kotlin, process lifecycle, cold start)	Spike in week 1 of phase 7; keep the Kotlin side small (index lookup + unlock activity), all crypto shared via a tiny Kotlin port tested against core vectors
Argon2 too slow in pure JS on Android	Native Argon2 module; tune memory cost after benchmark
Form detection misses on odd sites	Heuristic scoring + per-site overrides + manual "fill this field" from context menu
MV3 service worker suspension drops the unlock state	Keep key in `storage.session`, never in worker globals
Firefox MV3 differences (storage.session, identity)	WXT polyfills; Firefox build in CI from day 1
Losing the master password = losing everything	Recovery kit with secret key at onboarding; enforced before first item is saved
Passkey interception breaks some sites or clashes with the browser's own passkey UI	Per-site opt-out, always offer the browser/phone fallback, test matrix of the top 20 passkey sites
Android passkey provider requires Android 14+	Older devices keep passwords + TOTP autofill; minimum version documented

Decisions (settled 30 Oct 2026)

- [x] ~~Sync: self-hosted server on your Linux VM.~~
- [x] ~~Users: single user for now; schema and API keep user_id so more users can be enabled later.~~

- [x] ~~Distribution: sideloaded APK and unlisted extensions (Chrome Web Store unlisted, Firefox signed XPI).~~
- [x] ~~Domain: voult.franciscoliveira.com (API, WebSocket, favicon proxy, update manifests).~~